

Corrigé TP : Scans de Vulnérabilités et Détection d'Anomalies (Windows & Linux)

1. Réponses aux questions de guidage par partie

Partie 1 : Cartographie Rapide et Bannières Réseau

1.1 Inspection des bannières (*Banner Grabbing*)

- **Le numéro de version exact de l'application apparaît-il en clair dans la bannière ?**
 - Oui, par défaut la plupart des services non durcis renvoient leur version complète (ex. OpenSSH_8.9p1 Ubuntu-3ubuntu0.6, Apache/2.4.52 (Ubuntu), ou l'en-tête Server: Microsoft-IIS/10.0).
- **Pourquoi la divulgation de cette version représente-t-elle un gain de temps majeur pour un attaquant ?**
 - Elle évite à l'attaquant de tester des exploits à l'aveugle au risque de faire planter le service ou de déclencher des alertes dans les sondes IDS/IPS. Il peut cibler directement les failles CVE répertoriées pour cette version précise.

1.2 Détection active via Nmap et les scripts NSE

- **Quels services sont identifiés comme vulnérables par Nmap ?**
 - Sur Linux : détection éventuelle de versions d'Apache ou de protocoles d'écoute non chiffrés.
 - Sur Windows : détection possible de vulnérabilités SMB si SMBv1 est actif ou si les correctifs mensuels accumulent du retard.
- **Alertes SMB sur Windows :**
 - Mise en évidence de l'absence de signature SMB obligatoire (message_signing: disabled), du dialecte SMBv1 ou de failles de type fuite d'informations NetBIOS.

Partie 2 : Préparation des Accès d'Audit Authentifié

2.1 Cible Linux (Commandes de validation)

```
# Création et configuration du compte de scan
sudo useradd -m -s /bin/bash auditscan
echo "auditscan:AuditSecurite2026!" | sudo chpasswd
echo "auditscan ALL=(ALL) NOPASSWD: ALL" | sudo tee /etc/sudoers.d/auditscan
sudo chmod 440 /etc/sudoers.d/auditscan
```

```
# Test de validation depuis la machine d'audit
ssh auditscan@<IP_LINUX> "sudo uname -a && sudo id"
# Résultat attendu : uid=0(root) gid=0(root) groups=0(root)
```

2.2 Cible Windows Server (PowerShell Administrateur)

```
# Configuration du service WinRM
Enable-PSRemoting -Force
Set-Service -Name WinRM -StartupType Automatic
Start-Service -Name WinRM

# Vérification du pare-feu local
Get-NetFirewallRule -DisplayGroup "Gestion à distance de Windows" | Select-Object
DisplayName, Enabled, Direction

# Autorisation explicite du flux HTTP WinRM si nécessaire
New-NetFirewallRule -Name "WinRM-HTTP-In" -DisplayName "WinRM HTTP 5985" -Enabled
True -Direction Inbound -Protocol TCP -LocalPort 5985 -Action Allow
```

Partie 4 : Analyse des Résultats et Piège du Rétroportage

4.2 Investigation du Rétroportage (*Backporting*)

- **La CVE alertée par le scanner a-t-elle été corrigée malgré la version inchangée ?**
 - Oui. Dans le journal des modifications de Debian/Ubuntu (apt-get changelog apache2 ou openssh-server), la mention de la CVE est explicitement présente avec un numéro de révision de distribution (ex. 2.4.52-1ubuntu4.7). Le code vulnérable a été patché sans modifier le numéro de version majeure du logiciel.
- **Différence fondamentale entre scan non authentifié et authentifié :**
 - Le scan **non authentifié** lit uniquement la bannière réseau Apache 2.4.52 et applique une règle statique : version < 2.4.54 $\Rightarrow$ alerte critique (**Faux positif**).
 - Le scan **authentifié** interroge la base locale de paquets (dpkg -l) et constate que la sous-version installée contient le correctif (**Vrai statut : Non vulnérable**).

Partie 5 : Actions Correctives Immédiates Validées

5.1 Désactivation des services non indispensables

- **Linux (CUPS) :**

```
sudo systemctl stop cups cups-browsed
sudo systemctl disable cups cups-browsed
sudo systemctl mask cups
```

- **Windows (Spouleur) :**
Stop-Service -Name Spooler -Force
Set-Service -Name Spooler -StartupType Disabled

5.2 Restriction Pare-feu

- **Linux (ufw) :**
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from <IP_AUDIT> to any port 22 proto tcp
sudo ufw enable
- **Windows (Pare-feu avancé) :**
New-NetFirewallRule -DisplayName "Filtrage RDP Admin" -Direction Inbound -LocalPort 3389 -Protocol TCP -Action Allow -RemoteAddress "<IP_AUDIT>"
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True

2. Livrable : Matrice d'Analyse des Vulnérabilités Complétée

Équipement	Vulnérabilité / Port détecté	Score CVSS & Sévérité	Vecteur (AV)	Type	Action de remédiation validée
Linux	Démon CUPS actif (cups-browsed sur port 631 UDP)	9.9 (Critical)	AV:N	Vrai Positif	Service stoppé, masqué et désactivé via systemctl.
Linux	Fausse faille RCE Apache (version amont obsolète)	9.8 (Critical)	AV:N	Faux Positif (<i>Backporting</i>)	Vérification du changelog apt-get ; exception consignée dans l'audit.
Linux	Vulnérabilité	7.8 (High)	AV:L	Vrai Positif	Mise à jour immédiate

	d'élévation locale de privilèges (sudo)				du paquet (apt --only-upgrade install sudo).
Windows	Spouleur d'impression actif (<i>PrintNightmare</i>)	8.8 (High)	AV:N	Vrai Positif	Service Spooler arrêté et désactivé par commande PowerShell.
Windows	Protocole obsolète SMBv1 actif (risque <i>EternalBlue</i>)	8.1 (High)	AV:N	Vrai Positif	Désactivation de la fonctionnalité facultative SMB1Protocol.
Windows	Écoute RDP globale (3389/TCP) sans restriction d'IP	7.5 (High)	AV:N	Vrai Positif	Règle de pare-feu restreignant l'accès RDP à l'IP d'administration.